

Cybersecurity Incident Registry

Documentazione amministrativa completa

Versione PDF statica della documentazione amministrativa, aggiornata agli ultimi sviluppi dell'applicazione.

Indice

1. Responsabilità, prerequisiti e metodo di lavoro
2. Menu Admin e organizzazione delle voci
3. Utenti, ruoli, MFA, LDAP e SSO
4. Profili OAuth2/SSO multipli
5. Liste configurabili, label e raccomandazioni
6. Flussi operativi incidenti
7. Dati organizzativi e logo
8. SMTP, template e scheduler notifiche
9. Promemoria incidenti e recupero post-riavvio
10. Help contestuale dei campi incidente
11. Template PDF e mapping moduli
12. Audit, retention, purge ed export CSV
13. Full export, import, backup e ripristino
14. HTTPS/SSL opzionale
15. Lingua, documentazione e menu Aiuto
16. Checklist operative e troubleshooting
17. Modelli incidente
18. Full import e import tenant
19. Riferimento obbligatorio degli incidenti
20. Destinatari esterni nei dati incidente
21. Rendering Markdown sicuro
22. Layout campi incidenti

Guida completa alla configurazione, alla sicurezza e alla manutenzione dell'applicazione.

Amministrazione chiara, verificabile e ripetibile

Versione applicativa: 0.6.0-3 · Versione 0.6.0-3 della guida amministrativa.

Applicazione

Versione applicativa 0.6.0-3

Build

Nota Versione 0.6.0-3 della documentazione amministrativa.

Plugin Alfresco

La voce Admin → Plugin Alfresco consente di abilitare il plugin opzionale, disabilitato per default, e configurare endpoint API, credenziali, site, cartella di destinazione, timeout e verifica TLS. Quando abilitato, la sezione Documenti degli incidenti consente upload e download tramite API Alfresco.

1. Responsabilità, prerequisiti e metodo di lavoro

Flusso amministrativo consigliato

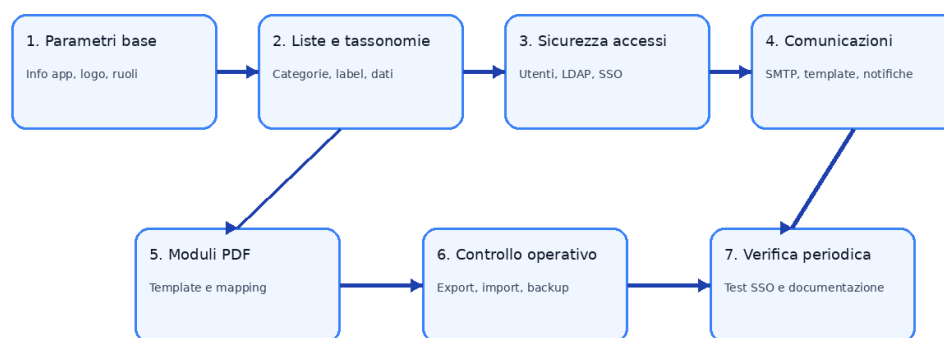


Figura 1 - Flusso amministrativo consigliato

Le funzioni amministrative sono riservate all'utente admin e agli utenti con ruolo admin. Le modifiche effettuate in quest'area incidono su sicurezza, dati, report, notifiche e procedure operative.

Prima di modificare configurazioni critiche, verificare di avere un backup recente e una procedura di ripristino. Le modifiche devono essere tracciabili: il sistema registra le operazioni nella tabella di audit e riduce il flooding collassando record consecutivi identici.

Prerequisiti consigliati

- Account amministrativo personale e non condiviso.
- Parametri SMTP, LDAP, SSO o SSL validati prima dell'attivazione.
- Directory persistente per documenti, certificati e file applicativi.
- Procedura di backup PostgreSQL e full export applicativo. Backup configurabili da menu Admin

La voce Admin → Backup consente di configurare backup periodici e on-demand. Le categorie selezionabili con scelta multipla sono incidenti in CSV, database, template, loghi e uploads; per default sono tutte selezionate e, se restano tutte attive, il risultato è un full backup applicativo. La schedulazione usa una sintassi cron-like a cinque campi ed è disabilitata per default. Le destinazioni disponibili sono file locale su filesystem POSIX, S3/compatibile e file scaricabile solo per backup on-demand. L'amministratore può abilitare e-mail di notifica all'utente admin per successi o errori e può caricare un archivio per le operazioni di restore/verifica.

Stato servizi e scheduler

La voce Admin → Stato mostra thread scheduler con pallino colorato attivo/non attivo, heartbeat, cicli task in scadenza, cicli promemoria specifici, scheduler backup, errori e contatori operativi.

2. Menu Admin e organizzazione delle voci

Il menu Admin è organizzato in sottogruppi collassabili per evitare un elenco troppo lungo. Al caricamento pagina nessun sottogruppo è aperto per default, così la navigazione resta ordinata e prevedibile.

Le voci disponibili dipendono dal ruolo dell'utente. Le aree principali riguardano identità, configurazioni operative, notifiche, moduli, audit, SSL e dati organizzativi.

2a. Hardening produzione

Per l'esercizio reale impostare CIR_PRODUCTION=1 , usare PostgreSQL, generare una SECRET_KEY casuale di almeno 32 caratteri e definire una password iniziale admin temporanea robusta. Il file docker-compose.yml non contiene segreti: copiare .env.example in .env e modificare tutti i valori prima dell'avvio.

L'applicazione applica protezione CSRF automatica alle form mutative, header di sicurezza, cookie HttpOnly/SameSite e cookie Secure in produzione. Lo scheduler interno usa un lock PostgreSQL per evitare esecuzioni duplicate con più worker o repliche Kubernetes.

2b. Variabili di ambiente e gestione container

La gestione del container è documentata anche nel file docs/CONTAINER_ENVIRONMENT.md . Prima dell'avvio in produzione copiare .env.example in .env , sostituire tutti i segreti e verificare che le directory sotto /data siano montate su volumi persistenti o PVC.

Area Variabili principali Indicazioni operative

Database e segreti DATABASE_URL , SECRET_KEY , ADMIN_INITIAL_PASSWORD , POSTGRES_PASSWORD Usare PostgreSQL in produzione, una SECRET_KEY casuale di almeno 32 caratteri e una password admin temporanea robusta. POSTGRES_DB e POSTGRES_USER devono essere coerenti con DATABASE_URL .

Produzione e sicurezza HTTP CIR_PRODUCTION , SESSION_COOKIE_SECURE , CIR_FORCE_HSTS , MAX_CONTENT_LENGTH Impostare CIR_PRODUCTION=1 e cookie sicuri quando l'applicazione è servita via HTTPS. CIR_FORCE_HSTS=1 è utile dietro reverse proxy TLS.

Storage persistente UPLOAD_DIR , LOGO_DIR , FORM_TEMPLATE_DIR , SSO_LOGO_DIR , SSL_DIR Contengono allegati, logo applicativo, template PDF, loghi SSO e certificati. Devono essere inclusi nei backup insieme al database PostgreSQL.

HTTP/HTTPS e Unicorn PORT , WEB_CONCURRENCY , GUNICORN_THREADS , GUNICORN_TIMEOUT , SSL_ENABLED , SSL_PORT , SSL_CERT_FILE , SSL_KEY_FILE L'entrypoint avvia sempre HTTP e avvia HTTPS quando abilitato e quando certificato e chiave sono leggibili. Dimensionare worker e thread in base alle risorse disponibili.

Scheduler CIR_ENABLE_DEADLINE_SCHEDULER , CIR_DEADLINE_SCHEDULER_POLL_SECONDS Lo scheduler è abilitato di default e usa lock PostgreSQL in deployment multi-replica. Disabilitarlo solo se viene gestito da un componente esterno.

Metadati applicazione APP_NAME , APP_VERSION , APP_BUILD , APP_AUTHOR , APP_AUTHOR_EMAIL Valori mostrati in Info → Applicazione e utili per audit, rilascio e supporto.

Operazioni tipiche: docker compose up -d per avviare, docker compose logs -f web per i log, docker compose down per fermare senza cancellare dati. Non usare docker compose down -v in produzione perché rimuove i volumi.

In Kubernetes i segreti applicativi sono letti da cir-secrets ; le aree persistenti devono essere montate tramite PVC. In caso di aggiornamento eseguire prima backup del database e dei volumi, poi ricostruire o ridistribuire l'immagine.

3. Utenti, ruoli, MFA, LDAP e SSO

Da Admin → Utenti si gestiscono account locali, LDAP e SSO, ruoli, indirizzi e-mail, MFA e rimozione degli account. È consigliato mantenere almeno un account admin locale di emergenza anche se LDAP o SSO sono attivi.

La ricerca utenti è separata in campi dedicati per username, nome, email, backend, ruolo e tenant di appartenenza; selezionando un tenant vengono mostrati solo gli account appartenenti a quel perimetro. La pagina utenti mostra record collapsabili, chiusi per default, per rendere più leggibile la manutenzione degli account. Aprendo un record si possono aggiornare i dati account e, dopo il salvataggio, la pagina torna allo stesso record mantenendo aperta la scheda. L'utente locale admin e i superuser possono anche reimpostare la password degli account con login locale; per LDAP e SSO la password resta gestita dal provider esterno. Per ogni utente diverso dall'utente locale admin si possono aggiungere, rimuovere o modificare i tenant associati scegliendo il ruolo specifico per ciascun tenant. Nella stessa scheda è possibile configurare il tenant attivo predefinito dell'utente: viene usato al login o quando la sessione non ha ancora uno switch esplicito. Gli utenti con più tenant accessibili vedono nella barra superiore un selettore che applica immediatamente il tenant scelto alla sessione corrente. L'utente locale admin resta sempre superuser globale e non espone modifiche tenant-specifiche.

MFA TOTP può essere usato per aumentare la sicurezza degli accessi. LDAP consente l'autenticazione verso directory esterne; SSO/OAuth2 consente l'integrazione con provider OpenID Connect.

Nella tabella utenti, la colonna Tipo login distingue gli account SSO anche per provider: mostra il nome configurato del provider, l'id del profilo e il backend tecnico nel formato sso:<id profilo>. In questo modo lo stesso username può essere riconosciuto correttamente se esiste come login locale, LDAP o su più provider SSO differenti.

La rimozione di un utente elimina l'account e i token MFA associati, impedendo nuovi accessi. Incidenti, promemoria e audit restano conservati: il sistema svincola solo il riferimento tecnico all'account rimosso, preservando la tracciabilità storica. Per sicurezza non è possibile rimuovere l'utente amministratore correntemente collegato né l'ultimo amministratore rimasto.

Ruolo Uso consigliato

admin Configurazione e manutenzione applicativa.

writer Operatori che creano e aggiornano incidenti.

reader Revisori o utenti di sola consultazione.

operator Accesso operativo circoscritto.

3.1 Multi-tenancy e tenant

La voce Admin → Tenant, visibile ai soli utenti con ruolo superuser, consente di aggiungere, modificare e cancellare tenant. Il tenant default viene creato automaticamente e non può essere eliminato. Durante la creazione di un nuovo tenant è possibile clonare le configurazioni di un tenant esistente; se non viene scelto un tenant sorgente viene usato il tenant default.

Ogni utente può appartenere a più tenant con ruoli differenti. Una membership con ruolo superuser rende l'utente superuser indipendentemente dal tenant; l'utente locale admin è sempre superuser. Gli utenti con ruolo admin amministrano, esportano e importano solo i tenant in cui hanno ruolo admin. Solo i superuser e l'utente locale admin possono eseguire export/import globale. Il selettore del tenant attivo filtra immediatamente la pagina principale sugli incidenti del tenant selezionato. I superuser e l'utente locale admin possono inoltre spostare un incidente tra tenant dal dettaglio incidente; etichette, persone, raccomandazioni e label delle azioni vengono riusate o clonate nel tenant destinazione. Incidenti, azioni, documenti, workflow, liste configurabili, notifiche, plugin, destinatari, raccomandazioni, audit e backup sono separati per tenant. I moduli PDF e la loro configurazione, HTTPS/SSL, URL applicazione e fuso orario applicazione restano condivisi fra tutti i tenant.

4. Profili OAuth2/SSO multipli

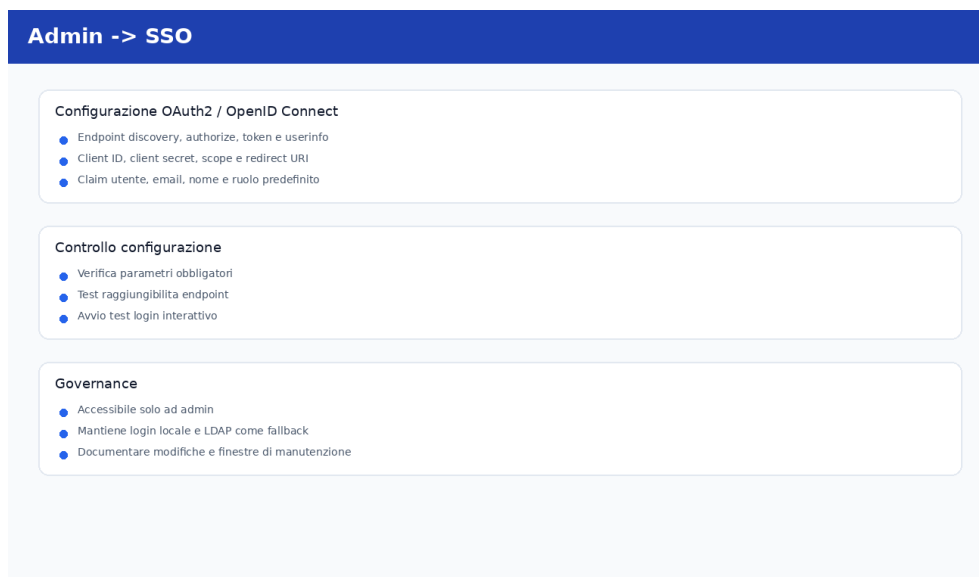


Figura 2 - Configurazione SSO e controllo connessione

L'applicazione supporta più profili OAuth2/OpenID Connect attivi contemporaneamente. La pagina di login mostra la scelta tra i provider attivi.

La callback/redirect URI mostrata nella form usa sempre schema https . La pagina offre un pulsante per aggiungere un profilo Google di esempio e un pulsante per aggiungere un profilo generico. Ogni profilo può avere anche un logo opzionale; se configurato, il logo viene mostrato nel pulsante di login. L'esempio Google usa il logo Google fornito dall'applicazione, sostituibile dalla form del profilo.

Loghi SSO/OAuth2 condivisi

I loghi SSO sono gestiti in uno storage condiviso dalla pagina Admin → SSO/OAuth2 . Il pulsante di caricamento aggiunge nuovi loghi allo storage persistente configurato con la variabile d'ambiente SSO_LOGO_DIR , mentre la configurazione del singolo profilo permette di scegliere uno dei loghi disponibili.

Google, Facebook e Apple sono forniti come loghi predefiniti e vengono copiati nello storage persistente al primo avvio se mancanti. I loghi caricati dagli amministratori non devono essere salvati nell'area statica del container, perché potrebbe essere effimera: in produzione il percorso indicato da SSO_LOGO_DIR , di default /data/sso_logos , deve essere montato su volume persistente o PVC.

La lista Storage loghi SSO mostra per ogni file il nome e l'anteprima grafica. Le anteprime sono servite dalla rotta applicativa persistente dei loghi, quindi devono funzionare sia per i loghi predefiniti sia per quelli caricati dalla UI. Se un'anteprima non compare, verificare che il file sia presente nella directory configurata da SSO_LOGO_DIR , che l'estensione sia supportata e che il volume persistente sia montato correttamente.

La rimozione di un logo dallo storage condiviso elimina automaticamente l'associazione dai profili SSO che lo utilizzavano, senza cancellare i profili. Il full export/import include anche i loghi SSO, utile per migrazioni e ripristini applicativi; resta comunque necessario mantenere backup della storage persistente.

Esempio Google

- Aggiungere il profilo Google.
- Registrare presso Google la redirect URI HTTPS mostrata dall'applicazione.
- Compilare Client ID e Client secret.
- Verificare scope, endpoint, claim e logo opzionale.
- Sostituire il logo Google predefinito solo se richiesto dalle regole di branding locali.
- Attivare il profilo e provare un login reale.

5. Liste configurabili, label e raccomandazioni

Le liste configurabili governano categorie, dati interessati, label azioni e altri valori usati dagli incidenti. Nelle label azioni la vista a schede separa nome, descrizione, tempo massimo, esportazione predefinita e operazioni automatiche. Il campo Tempo massimo (ore) specifica l'unità di misura e il flag Esportabile per default determina il valore iniziale delle nuove azioni.

Da Admin → Raccomandazioni si gestisce l'elenco delle raccomandazioni e il numero massimo selezionabile per incidente. Il default è 3; il limite è applicato nella UI e lato server ed è incluso nel full export/import tramite le configurazioni applicative.

Logica conseguenze automatiche

In Admin → Altre configurazioni la sezione dedicata permette di abilitare/disabilitare, aggiungere, rimuovere e personalizzare testo e condizioni delle regole che costruiscono il campo consequences dei moduli. Le conseguenze inserite nelle azioni dell'incidente vengono sempre aggiunte al risultato.

La stessa pagina include il pulsante Cleanup documenti orfani, che rimuove da uploads solo i documenti generati dall'applicazione non più collegati ad alcun incidente, lasciando intatti gli allegati caricati manualmente.

6. Flussi operativi incidenti

Da Admin → Flussi operativi incidenti l'amministratore definisce le operazioni attese per gli incidenti. Ogni passo usa una label azione presente nel database, quindi le azioni disponibili restano estendibili da Admin → Liste configurabili.

Per ciascun passo si indica se appartiene al flusso di default o a una categoria specifica, l'azione prevista, la tipologia di step, la descrizione operativa aggiuntiva, l'ordine e se lo step è richiesto ai fini degli avvisi procedurali. La stessa azione può comparire più volte con descrizioni diverse; ogni step può essere modificato, aggiunto o cancellato, incluso il default. La sezione Import/Export workflow consente anche di clonare, esportare, importare o eliminare interamente un flusso; tutte queste operazioni sono limitate al tenant attivo.

Il flusso di default iniziale contiene: Informazione iniziale, Analisi, Notifica allo CSIRT, Notifica al DPO, Comunicazione al Garante, Comunicazione all'utente e Conclusione. Nel dettaglio incidente la didascalia del riquadro inferiore usa la descrizione configurata della tipologia di step, per esempio Conferma o Esecuzione, seguita dalla descrizione della label azione se presente, altrimenti dal nome della label; la descrizione dello step viene mostrata nel riquadro superiore. Se la label azione ha un tempo massimo, l'incidente mostra limite, scadenza e tempo rimanente solo per gli step non ancora effettuati; uno step mancante con tempo rimanente minore o uguale a zero viene evidenziato come critico.

Nel dettaglio incidente i flussi delle categorie selezionate vengono sommati, i duplicati rimossi e, se assenti, viene applicato il default.

Nella pagina del dettaglio incidente i flussi delle categorie vengono uniti, i duplicati rimossi e, se nessun flusso di categoria è presente, viene applicato il workflow di default. Gli step sono riquadri cliccabili: il clic porta alla sezione Azioni e preseleziona la label associata, facilitando l'inserimento dell'azione mancante. Le descrizioni multilinea supportano Markdown sicuro, colori e dimensioni controllate, ad esempio **urgente**, elenchi, link Markdown, {color:red}testo{color} e {size:large}testo{size}; gli URL sono cliccabili nella pagina incidente e non intercettano il clic generale del riquadro. Gli avvisi procedurali sono posizionati subito sotto il workflow, usano lo stesso rendering Markdown e riportano anche il nome del task associato. Nel dettaglio incidente la prima fase non completata è segnalata con una grande freccia rossa; nella lista principale le icone distinguono warning attivi, workflow finalizzato ma incidente non chiuso e incidente chiuso senza warning.

Per le label azione è possibile associare operazioni automatiche. Il tag Chiusura del task in assenza di avvisi procedurali chiude l'incidente e imposta data e ora correnti nel fuso orario applicativo solo se, dopo l'azione appena inserita, non restano avvisi procedurali attivi; in caso contrario la chiusura viene bloccata e l'operatore riceve un avviso.

7. Dati organizzativi e logo

Le voci relative a titolare, struttura e responsabile alimentano i campi dinamici dei moduli e dei report. Il logo custom può essere caricato da interfaccia e viene usato dove previsto; il logo applicativo resta distinto e viene mostrato nei report PDF degli incidenti.

Se nessun logo custom è configurato, il report omette il logo custom e continua a mostrare il logo applicativo.

8. SMTP, template e scheduler notifiche

Le notifiche richiedono configurazione SMTP e template coerenti. Per le notifiche manuali/non schedulate il link diretto all'incidente viene inserito solo se il template contiene %INCIDENT_URL% .

I documenti generati da moduli PDF ereditano automaticamente solo i tag dei tipi di notifica associati direttamente al template modulo usato in Moduli → Configurazione . I documenti degli incidenti possono essere taggati con uno o più tipi di notifica direttamente nella lista documenti tramite drag & drop. Questi tag guidano la preselezione degli allegati in fase di invio, senza impedire all'operatore di modificare la selezione finale.

Ogni template manuale può essere associato opzionalmente a un template modulo PDF. In fase di invio da un incidente, i documenti generati da quel modulo vengono preselezionati automaticamente; l'operatore può comunque aggiungere altri documenti o deselectare quelli proposti. Se il documento atteso non è presente nell'incidente, il sistema mostra un warning non bloccante.

La voce Admin → Destinatari esterni gestisce la rubrica condivisa usata dai campi destinatario/CC delle notifiche manuali con destinatario libero, cioè non già preso da una configurazione applicativa: è possibile aggiungere, modificare, cancellare e cercare contatti per nome, email o note. Gli utenti non amministratori con ruolo writer possono gestire e ricercare nella stessa rubrica da Impostazioni → Destinatari esterni , senza accedere al menu Admin. In anteprima invio l'operatore può selezionare dalla rubrica un contatto visualizzando nome ed e-mail e usarlo come destinatario o CC. Per i destinatari liberi viene sempre richiesta una conferma esplicita prima dell'invio, con riepilogo di destinatario e CC; le nuove email inserite durante l'invio vengono aggiunte automaticamente alla rubrica usando il campo Riferimento dell'incidente come nome del destinatario, senza bloccare l'invio per chiedere dati aggiuntivi. L'invio manuale viene comunque respinto se il destinatario è vuoto o se destinatario/CC non hanno formato e-mail valido; quando il template consente la modifica manuale, i valori digitati dall'operatore nei campi Destinatario e CC dell'anteprima sono acquisiti direttamente al momento del submit, sia per l'invio sia per la conferma senza invio. Il CC modificabile viene precompilato con il default del template, se presente, ma l'eventuale svuotamento manuale prima della conferma viene rispettato e l'invio procede senza CC. Il CC modificabile viene precompilato con il default del template, se presente, ma l'eventuale svuotamento manuale prima della conferma viene rispettato e l'invio procede senza CC.

I placeholder disponibili nei template manuali includono %MEASURES_ADOPTED% ("lista delle contromisure adottate finora nell'incidente"), %RECOMMENDATIONS% ("lista delle raccomandazioni da fornire agli interessati, stesso valore del campo recommendations dei moduli"), %INCIDENT_URL% , %SITE% ("nome della struttura dove si è verificato l'incidente") e %STATISTICS% , che allega alla notifica il report con le statistiche in formato PDF, e %APP_INFO% , che inserisce nome applicazione e versione.

Le notifiche task in scadenza usano una pianificazione stile cron: orari specifici o intervalli. Gli slot sono calcolati dalla mezzanotte della timezone applicativa, non dall'avvio dell'applicazione. Lo scheduler registra audit solo quando invia notifiche oppure nello slot pianificato in cui avrebbe dovuto inviarle anche se non trova task.

Per evitare duplicati, lo stato dello slot viene salvato prima dell'invio: il claim persistente impedisce reinvii nello stesso intervallo anche se più worker, repliche o controlli opportunistici tentano di inviare contemporaneamente. Ogni ciclo elimina inoltre stati residui riferiti a incidenti cancellati.

In Impostazioni → Notifiche è disponibile una sezione di riepilogo con le prossime notifiche schedulate nelle 24 ore successive, ordinate per ora e complete di tipo notifica, incidente e destinatari previsti. La lista include i promemoria puntuali degli incidenti e gli slot futuri delle notifiche automatiche sui task in scadenza.

Stato notifiche schedulate e CC

La pagina Notifiche mostra lo stato programmata , inviata o errore e gli esiti recenti aggiornati automaticamente dallo scheduler. Quando un template consente la modifica manuale del CC, l'anteprima precompila il default del template se presente; se l'operatore lo svuota prima della conferma, l'invio viene effettuato senza CC.

I template manuali espongono anche %RISK_RIGHTS_FREEDOM% , %RESP% , %RESP_EMAIL% , %DIRECTOR% e %DIRECTOR_ROLE% . Il vecchio placeholder %PERSONAL_DATA% viene migrato automaticamente nei template esistenti.

9. Promemoria incidenti e recupero post-riavvio

I promemoria puntuali degli incidenti sono definiti dagli operatori con data, ora, messaggio e CC opzionali. Lo scheduler invia i promemoria al personale associato all'incidente tramite un thread dedicato, separato dal controllo delle scadenze azioni.

Dopo un riavvio, i promemoria specifici non periodici già scaduti e non ancora marcati come inviati in sent_at vengono recuperati tutti. Il claim tecnico impedisce solo invii contemporanei dello stesso record e non applica il blocco per periodo. L'intervallo del controllo automatico è configurabile nelle impostazioni notifiche, con default 60 secondi; ogni ciclo produce un audit. Lo stesso controllo può essere eseguito manualmente da Notifiche → Impostazioni → Controllo promemoria specifici; gli audit di salto riportano identificativo, dettagli del promemoria, incidente e motivo. Per le notifiche periodiche, invece, il recupero invia solo l'ultima notifica prevista per tipologia, evitando di generare una sequenza arretrata di messaggi.

10. Help contestuale dei campi incidente

La form di dettaglio incidente include icone informative per i campi principali. I testi di help spiegano obbligatorietà, destinatari, periodo della violazione, data/ora di venuta a conoscenza, rischio per diritti e libertà, silenziamento delle notifiche deadline e campi numero interessati/volume dati. Gli amministratori devono mantenere le procedure operative allineate a queste definizioni.

11. Template PDF e mapping moduli



Figura 3 - Configurazione template PDF e mapping

I template PDF sono analizzati per ricavare i campi AcroForm. L'amministratore associa ciascun campo del modulo a un campo del database incidenti o a un valore dinamico. La stessa configurazione consente di associare al template uno o più tag di tipo notifica tramite drag & drop; i tag sono mostrati con il nome del tipo e saranno applicati per default ai documenti generati da quel template. La compilazione usa font e dimensioni configurate.

Prima della generazione, l'applicazione verifica i dati mancanti e chiede all'utente di completarli nella sezione corretta.

Plugin AI Chatbot AIBot/Alex

La voce Admin → Plugins consente di attivare il plugin opzionale AI Chatbot, scegliere un solo motore tra ChatGPT, Claude, Gemini, Ollama e Perplexity, configurarne endpoint/modello/API key e caricare documenti procedurali usati come knowledge base. Le API key già configurate sono indicate solo in forma offuscata: il valore reale non è visualizzabile e può soltanto essere sovrascritto. Il pulsante di reset globale delle configurazioni backend ripristina motore attivo, endpoint, modelli e API key ai valori di default, mentre i pulsanti presenti nei singoli motori ripristinano solo endpoint, modello e API key del backend selezionato. I reset non modificano abilitazione plugin o opzione di contesto database.

L'uso dello snapshot database è opzionale, disattivato per default e filtrato per escludere dati personali, credenziali, token, email, allegati binari e testo libero potenzialmente identificativo. Il widget globale usa posizionamento anti-collisione su desktop e pulsante mobile accanto al menu.

12. Audit, retention, purge ed export CSV

La tabella audit registra operazioni utente, scheduler e task automatizzati. I dettagli sono sintetici e leggibili, evitando payload estesi non utili alla consultazione.

La retention temporale è configurabile in mesi, giorni, ore e minuti, con default a 6 mesi. È inoltre previsto un purge automatico al superamento del numero massimo di record, default 10000, configurabile in Admin → Audit .

Dalla stessa pagina è possibile eseguire purge manuale mantenendo solo un numero specificato di record oppure eliminando i record più vecchi di una data specifica. È disponibile anche l'export CSV dell'audit corrente, rispettando i filtri selezionati. La consultazione è paginata, con default 20 e massimo 100 record per pagina. Le date e ore mostrate, filtrate, usate per il purge ed esportate in CSV sono espresse nella timezone configurata dell'applicazione.

13. Full export, import, backup e ripristino

Il full export/import include incidenti, documenti, moduli, configurazioni, audit, stati notifiche, promemoria, profili SSO, loghi SSO e certificati SSL. L'export completo è utile per migrazioni e backup applicativi, ma non sostituisce un backup PostgreSQL e della storage persistente.

Backup consigliato

- Eseguire backup database.
- Salvare la directory persistente dei file.
- Scaricare periodicamente il full export.
- Testare il ripristino in ambiente separato.

14. HTTPS/SSL opzionale

Il container espone la porta 8443 per HTTPS/SSL opzionale. L'accesso HTTP su porta 8000 resta sempre disponibile e non deve essere bloccato dall'assenza di certificati.

HTTPS può essere abilitato tramite variabile di environment in Docker Compose o Kubernetes e dalla voce Admin → HTTPS/SSL . I certificati host possono essere forniti dalla configurazione o caricati da interfaccia web. Se HTTPS è richiesto ma non sono disponibili certificati validi, l'applicazione continua ad avviare l'accesso HTTP.

15. Lingua, documentazione e menu Aiuto

L'applicazione mantiene interfaccia e documentazione in italiano e inglese. Le istruzioni funzionali vengono recepite in italiano e tradotte anche nella versione inglese.

Il menu Aiuto contiene Documentazione utente , Documentazione amministrativa e Note di rilascio . Le voci dirette di download PDF non sono nel menu: ogni pagina contiene il proprio pulsante per scaricare la versione PDF.

Il file README.md è mantenuto in italiano e README_en.md in inglese.

16. Checklist operative e troubleshooting

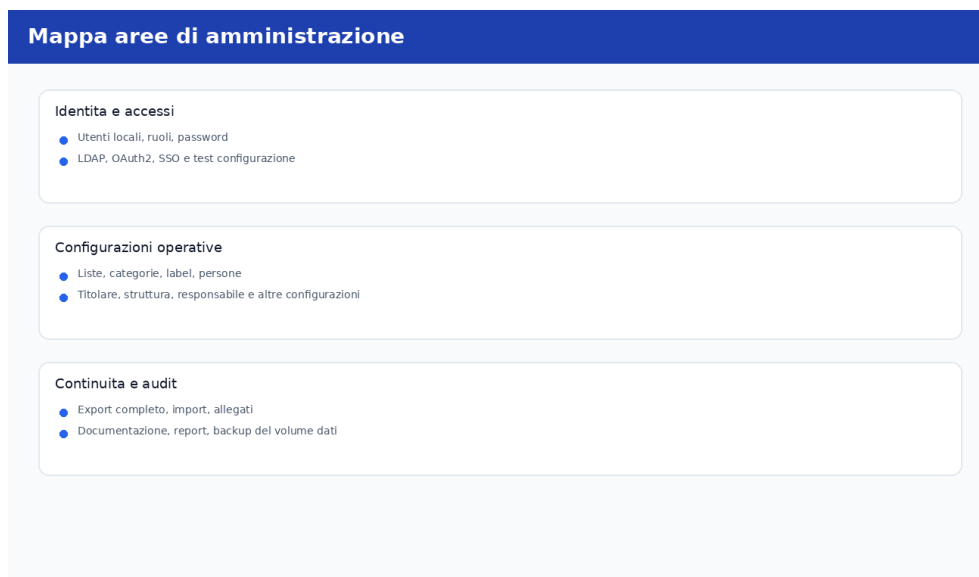


Figura 4 - Mappa delle aree di governance amministrativa

Checklist mensile

- Verificare backup e restore test.
- Controllare audit, retention e purge.
- Verificare invio notifiche automatiche e promemoria.
- Controllare validità certificati SSL e configurazioni SSO.
- Rivedere utenti attivi e ruoli assegnati. Problemi comuni
- SSO non funziona: verificare redirect URI HTTPS, client secret, endpoint e claim.
- Mail non arrivano: controllare SMTP, template, destinatari e audit dello scheduler.
- Modulo PDF incompleto: controllare mapping e campi obbligatori dell'incidente.
- Audit troppo grande: verificare retention, limite massimo e purge manuale.

17. Modelli incidente

Da Admin → Modelli incidente l'amministratore può definire profili predefiniti per inizializzare un nuovo incidente. Ogni modello può contenere nome, riferimento, destinatario, descrizione, gravità, stato, indicazione rischio per diritti e libertà, categorie, dati interessati, personale coinvolto e raccomandazioni. Le azioni e i documenti non sono inclusi nei modelli. L'ordine delle categorie selezionate tramite drag and drop viene conservato nel salvataggio e nella successiva modifica del modello.

È possibile creare un modello anche da un incidente esistente: il sistema copia solo i dati di bootstrap ed esclude azioni e documenti. In fase di creazione da modello la data e l'ora di inizio dell'incidente sono sempre valorizzate con il momento corrente. I modelli sono applicabili solo durante la creazione di un nuovo incidente: sugli incidenti già esistenti resta possibile modificare manualmente i dati generali, ma non applicare un modello.

Admin → Utenti include una ricerca per username, nome, email, backend e ruolo. La rimozione utenti registra l'evento di audit dopo aver riallineato la sequence PostgreSQL per evitare errori di chiave duplicata su database importati.

18. Full import e import tenant

Il Full import globale sostituisce integralmente il database applicativo: dopo la validazione dell'archivio, lo schema viene distrutto e ricreato prima del ripristino. Questa modalità è riservata ai superuser e all'utente locale admin, elimina dati precedenti, tabelle residue e sequence PostgreSQL disallineate. Prima di usarla in produzione eseguire sempre un backup del database e dei volumi persistenti.

Gli admin di tenant possono importare solo archivi esportati in modalità tenant-scoped e solo nel tenant attivo per cui hanno ruolo admin. In questa modalità vengono sostituiti soltanto dati e configurazioni del tenant interessato; altri tenant, utenti globali e configurazioni condivise non vengono modificati.

18.1 Correzione sequence utenti PostgreSQL

Durante la creazione di nuovi utenti, inclusi account locali, LDAP creati al primo login e SSO creati automaticamente, l'applicazione riallinea la sequence PostgreSQL della tabella user . Se l'inserimento manuale da Admin → Utenti rileva una collisione user_pkey , il sistema esegue rollback, riallinea la sequence in modo persistente e ritenta l'inserimento. Questa protezione evita errori dopo full import, restore o caricamenti dati con ID espliciti.

18.2 Correzione sequence audit PostgreSQL

Le operazioni su utenti scrivono sempre un evento nel registro audit. Dopo import o restore PostgreSQL, l'applicazione riallinea automaticamente la sequence di audit_log prima degli inserimenti critici e riprova l'operazione audit in caso di collisione audit_log_pkey . Questo evita errori durante aggiunta, modifica e cancellazione degli utenti.

18.3 Sequence database e import completi

Dalla versione 0.6.0-3 il sistema riallinea automaticamente tutte le sequence PostgreSQL delle tabelle applicative con chiave primaria intera dopo Full import e restore. Questo evita errori duplicate key value violates unique constraint nelle successive operazioni di creazione di utenti, incidenti, azioni, documenti, workflow, template, destinatari, backup e record audit.

Il Full import resta distruttivo: lo schema viene ricreato completamente prima del caricamento dei dati e le sequence vengono riallineate anche dopo il commit del restore, così le clonazioni successive di tenant o workflow non possono riutilizzare chiavi primarie già importate, ad esempio su config_label_pkey .

19. Riferimento obbligatorio degli incidenti

Il campo Riferimento è obbligatorio per ogni incidente e viene validato lato interfaccia e lato server. Durante migrazioni e Full import, eventuali record storici privi di riferimento vengono normalizzati con un valore tecnico basato sull'id, così il database resta coerente con la regola applicativa.

20. Destinatari esterni nei dati incidente

Questa sezione documenta l'uso amministrativo della rubrica nei dati incidente e nei modelli. Nella sezione Dati Generali degli incidenti e in Admin → Modelli incidente la rubrica dei destinatari esterni può compilare Riferimento, Destinatario o E-mail Destinatario. La ricerca LDAP incidente può restituire più utenti: la pagina mostra tutti i risultati e, per ogni riga, tutti gli attributi configurati in LDAP come "Attributi di ricerca incidenti", lasciando all'operatore la selezione della riga da usare. Se l'E-mail Destinatario viene valorizzata deve contenere un indirizzo e-mail valido e deve essere presente anche Riferimento o Destinatario. Le nuove e-mail non già presenti in rubrica vengono aggiunte automaticamente usando come nome Destinatario o Riferimento. Le notifiche manuali non possono essere inviate né confermate senza almeno un destinatario effettivo.

21. Rendering Markdown sicuro

Descrizioni workflow, avvisi procedurali e chatbot usano un renderer Markdown sicuro. Sono supportati titoli, elenchi, grassetto, corsivo, codice, link HTTP/HTTPS, pulsanti link {button:Etichetta|URL} e tag controllati per colore e dimensione, ad esempio {color:red}testo{/color} , {color:#0b7285}testo{/color} , {size:large}testo{/size} e {size:14px}testo{/size} . I pulsanti accettano anche URL relativi o ancore della pagina corrente, ad esempio {button:Dati generali|#incident-main} . L'HTML libero resta escapato e le notifiche schedulate rimuovono la formattazione prima dell'invio.

22. Layout campi incidenti

La voce Admin → Layout campi incidenti consente di configurare quali campi mostrare nella form Nuovo incidente e quali riquadri di ricerca mostrare nella sezione Dati generali degli incidenti. Nel pannello Nuovo incidente le voci Ricerca destinatari esterni e Ricerca utente via LDAP sono separate; nel pannello Dati generali incidente le stesse due ricerche possono essere mostrate o nascoste indipendentemente. I campi obbligatori essenziali restano sempre visibili. In assenza di una configurazione già salvata, tutte le voci risultano selezionate per default.